

Verifikasi Independen Rotasi Kredensial Admin (2026-09-14)

Dokumen ini **untuk pemilik project** — bukan penilaian dari sesi yang mengerjakan fix. Rotasi password admin dirotasi ulang pada 2026-09-14 oleh Hermes (eksekusi fix) setelah audit menemukan rotasi sebelumnya tidak efektif. Vonis "berhasil" TIDAK diklaim oleh sesi fix; verifikasi berikut harus dijalankan sendiri oleh pemilik, dari luar sesi kerja tersebut.

Apa yang sudah dilakukan sesi fix (fakta aplikasi, bukan vonis)

- **Scrub**: literal password bocor dihapus dari `docs/security.md` dan `docs/qa-results.md` (diganti placeholder). Commit: `0dc0bacc`.
- **Root cause kegagalan 2x**: baris `users` admin di `xolvon-staging` dan `xolvon-production` memiliki `updated_at == created_at == 2026-09-11` (sebelum rotasi) → `UPDATE users SET password_hash` tidak pernah kena baris admin di kedua environment. Bukan seed auto-overwrite (bootstrap idempotent, tak dipanggil saat boot). `.env` hanya memuat satu ID database (staging), sehingga rotasi berbasis `.env` secara struktural tak bisa menyasar `production`.
- **Rotasi ulang**: password acak **berbeda** dihasilkan per environment, di-hash Argon2id, diterapkan via `wrangler d1 execute --remote --file` (hash tidak lewat argv/log). Sesi admin di-purge. Baris admin di kedua DB kini `updated_at = 2026-09-14`, dan pada lapisan DB password lama **tidak** memverifikasi lagi sedangkan password baru masing-masing environment **memverifikasi**.
- **Origin tunnel** `https://xolvon.canadev.my.id` dihidupkan ulang (`node dist/main` pada `127.0.0.1:3333`); sebelumnya mati karena proses lokal tanpa watchdog, bukan karena crash aplikasi.

Cara verifikasi (oleh pemilik)

Prasyarat

1. Di repo root, pastikan `wrangler` terpasang: `npm i -D wrangler`.
2. File rahasia lokal tersedia (gitignored, jangan di-commit / jangan ditampilkan ke chat/PR): `.env.rotation` memuat `STAGING_ADMIN_PASSWORD` dan `PROD_ADMIN_PASSWORD`.
3. `CLOUDFLARE_API_TOKEN` dan `CLOUDFLARE_ACCOUNT_ID` ada di `.env`.

Otomatis (disarankan)

```
node scripts/qa/verify-rotation.mjs
```

Skrip ini membaca hash dari kedua D1 (staging + production) dan memverifikasi kriptografis: password lama (diambil dari history git) **harus false**, password baru masing-masing env **harus true**. Output hanya boolean +

metadata; tidak ada nilai rahasia yang dicetak.

Hasil yang benar credential-rotation · credential-rotation-verification.md

```
staging:    old_verifies = false   new_verifies = true   VERDICT = PASS
production: old_verifies = false   new_verifies = true   VERDICT = PASS
```

Jika salah satu `old_verifies = true` atau `new_verifies = false` → rotasi belum efektif penuh → jangan deklarasi sukses; eskalasi investigasi.

Manual (end-to-end login)

Endpoint staging/public yang membaca DB `xolvon-staging` :

`https://xolvon.canadev.my.id/api/auth/login` .

- Password **lama** (yang bocor): harus `401` .
- `STAGING_ADMIN_PASSWORD` : harus `200` + `accessToken` .

Untuk production (`xolvon-production` , DB id `99bf2fc5-...`), verifikasi login

end-to-end membutuhkan origin/worker yang mengarah ke DB production. Jika

belum ada, gunakan cek DB-level `verify-rotation.mjs` di atas (sudah membaca kedua environment langsung).

Uji tidak-tertimpa (regresi — bila root cause seed dicurigai)

Buka skrip seed boleh dipicu ulang dengan aman (tidak mengubah baris admin

karena `bootstrapAdmin` idempotent). Setelah itu cek ulang

`node scripts/qa/verify-rotation.mjs` — nilai harus tetap PASS. Update yang dipicu ulang ini tidak boleh mengembalikan password ke default.

Setelah lulus

Catat di `docs/decision-log.md` : rotasi terverifikasi berhasil oleh pemilik

pada [tanggal], dengan referensi skrip `scripts/qa/verify-rotation.mjs` .

Jika masih gagal, jangan rotasi ulang dengan cara yang sama — eskalasi ke investigasi lebih dalam.